

TOSCANA DIAGNOSTICA S.r.l.

Sistema di Gestione Integrato

PROCEDURA DI ADEGUAMENTO ALLA DIRETTIVA NIS2

Area 08 – Sistema Informativo

Codice	Revisione	Data	Pagine
TD-SGI-PRO070_00	00	28/04/2026	12
Redatto da	Approvato da	Classificazione	Stato
RSGI	AD – Francesco Epifani	Distribuito a tutto il personale	In vigore

Responsabile del Documento	RSGI	Emissione del Documento
Francesco Epifani	Iacopo Cupelli	Francesco Epifani
28/04/2026	28/04/2026	28/04/2026

Toscana Diagnostica S.r.l.

Via di Pratignone, 13/4, 50019 Sesto Fiorentino (FI). Tel. e Fax: 055776511. Direttore Sanitario: prof. Gian Luigi Taddei.
P.IVA e C.F.: 07528130482, REA n. FI-709602 – Capitale Sociale: € 50.000,00 i.v.

1. Scopo e campo di applicazione

La presente procedura definisce le modalità con cui Toscana Diagnostica S.r.l. assicura la conformità agli obblighi derivanti dalla Direttiva (UE) 2022/2555 (NIS2), come recepita in Italia dal Decreto Legislativo 4 settembre 2024, n. 138 e dalle successive Determinazioni dell'Agenzia per la Cybersicurezza Nazionale (ACN). La procedura disciplina la registrazione e il mantenimento delle informazioni dichiarate sul Portale dei Servizi ACN nella sezione "Servizi NIS", la classificazione del soggetto, la gestione del ciclo di vita degli incidenti significativi di sicurezza con i relativi obblighi di notifica al CSIRT Italia (pre-allerta entro 24 ore, notifica completa entro 72 ore, relazione finale entro 30 giorni dalla notifica completa, ai sensi dell'art. 25 D.Lgs. 138/2024), l'attuazione delle Misure Tecniche e Organizzative Minime (MTOM) di cui all'art. 24 del medesimo decreto, la gestione dei fornitori ICT critici (due diligence iniziale, clausole contrattuali specifiche, monitoraggio periodico, audit triennale), nonché le attività di formazione obbligatoria, audit interno, esercitazioni di simulazione e miglioramento continuo a supporto della conformità NIS2.

La procedura si applica all'intera organizzazione di Toscana Diagnostica e a tutti i sistemi informativi, i servizi digitali, le reti, i dispositivi e i flussi di dati clinici, amministrativi e operativi che supportano l'erogazione dei servizi di diagnostica per immagini, laboratorio di analisi, medicina specialistica, medicina del lavoro, medicina dello sport e prelievi domiciliari. La procedura è integrata con il Sistema di Gestione della Sicurezza delle Informazioni conforme alla norma UNI CEI EN ISO/IEC 27001:2022 e con le procedure dell'Area 09 Privacy in materia di protezione dei dati personali (Reg. UE 2016/679 — GDPR e D.Lgs. 196/2003).

2. Riferimenti normativi e documentali

I principali riferimenti normativi e documentali della presente procedura sono riassunti nella tabella seguente.

Norma / Documento	Ambito
Direttiva (UE) 2022/2555 (NIS2)	Misure per un livello comune elevato di cybersicurezza nell'Unione
D.Lgs. 4 settembre 2024, n. 138	Recepimento in Italia della Direttiva NIS2 ("Decreto NIS")
Direttiva (UE) 2022/2557 (CER)	Resilienza dei soggetti critici, correlata a NIS2
Reg. di esecuzione (UE) 2024/2690	Modalità tecniche e metodologiche per l'attuazione di NIS2 in alcuni settori
L. 28 giugno 2024, n. 90	Disposizioni in materia di rafforzamento della cybersicurezza nazionale e reati informatici
Determinazioni ACN (DL 138/2024)	Disposizioni attuative su registrazione, notifica incidenti, MTOM
Determinazione ACN n. 38565/2024	Criteri per l'individuazione delle imprese collegate
Reg. (UE) 2016/679 (GDPR)	Protezione dei dati personali; coordinamento con notifica art. 33-34
D.Lgs. 196/2003 e ss.mm.ii.	Codice in materia di protezione dei dati personali
Direttiva 2011/24/UE, art. 3 lett. g)	Definizione di "prestatore di assistenza sanitaria" (perimetro NIS sanitario)
UNI CEI EN ISO/IEC 27001:2022	Sistemi di gestione per la sicurezza delle informazioni — Requisiti
UNI CEI EN ISO/IEC 27002:2022	Controlli di sicurezza delle informazioni
UNI CEI EN ISO/IEC 27005:2024	Gestione dei rischi per la sicurezza delle informazioni

UNI EN ISO 22301:2020	Sistemi di gestione per la continuità operativa
UNI EN ISO 31000:2018	Gestione del rischio — Linee guida
Framework Nazionale Cybersecurity (CINI/ACN)	Riferimento metodologico nazionale per la gestione del rischio cyber
D.Lgs. 231/2001, art. 24-bis	Reati informatici e responsabilità amministrativa degli enti
TD-SGI-MAN001_00	Manuale del Sistema di Gestione Integrato
TD-SGI-POL001_00	Politica integrata del SGI
TD-SGI-PRO001_00	Procedura di catalogazione e gestione della documentazione del SGI
TD-SGI-PRO019_00	Procedura di gestione degli incidenti ICT e data breach (Area 08)
TD-SGI-REG007_00	Registro dei Data Breach (Area 09)
TD-SGI-PRO034_00	Procedura di qualificazione e valutazione dei fornitori (Area 14)
TD-SGI-PRO054_00	Procedura di gestione della Comunicazione interna ed esterna (Area 01)
DNISA00056699	Conferma di registrazione ACN del 27/04/2026 (allegato esterno)

3. Definizioni

Ai fini della presente procedura si applicano le definizioni seguenti, coerenti con le definizioni del D.Lgs. 138/2024 e del Reg. (UE) 2024/2690.

Termine	Definizione
ACN	Agenzia per la Cybersicurezza Nazionale, autorità nazionale competente NIS ai sensi dell'art. 7 del D.Lgs. 138/2024
CSIRT Italia	Computer Security Incident Response Team istituito presso l'ACN, destinatario delle notifiche di incidente significativo
Soggetto importante	Soggetto pubblico o privato classificato come tale ai sensi dell'art. 6 del D.Lgs. 138/2024 in funzione di settore, dimensione e criteri specifici
Punto di contatto	Persona fisica designata dal soggetto NIS quale referente unico nei confronti dell'ACN, ai sensi dell'art. 8 del D.Lgs. 138/2024
Incidente significativo	Evento che compromette la disponibilità, l'autenticità, l'integrità o la riservatezza di dati o servizi, con effetti di rilievo, ai sensi dell'art. 25 D.Lgs. 138/2024 e Reg. UE 2024/2690
Quasi-incidente (near-miss)	Evento che avrebbe potuto compromettere la sicurezza ma il cui verificarsi è stato impedito o non si è prodotto
Pre-allerta (early warning)	Notifica preliminare trasmessa al CSIRT Italia entro 24 ore dalla conoscenza dell'incidente significativo
Notifica completa	Notifica trasmessa al CSIRT Italia entro 72 ore dalla conoscenza, con valutazione iniziale, gravità e impatto
Relazione finale	Relazione conclusiva trasmessa al CSIRT Italia entro 30 giorni dalla notifica completa, con analisi dettagliata e misure adottate
MTOM	Misure tecniche e organizzative minime imposte dall'art. 24 del D.Lgs. 138/2024 e dalle Determinazioni ACN attuative
Fornitore ICT critico	Fornitore di prodotti, servizi o processi ICT la cui indisponibilità o compromissione può determinare un impatto significativo sui servizi del soggetto
Codice DNISA	Identificativo univoco assegnato dall'ACN a ciascuna dichiarazione di registrazione NIS presentata sul Portale dei servizi
Punto unico di accesso	Sezione "Servizi NIS" del Portale ACN per registrazione, aggiornamento

dati, notifica incidenti e dialogo con l'Autorità

4. Caratterizzazione del soggetto e registrazione presso ACN

4.1 Identificativi del soggetto

Toscana Diagnostica è registrata sul Portale dei servizi ACN — sezione "Servizi NIS" — con i seguenti identificativi, riepilogati nella tabella sottostante.

Campo	Valore dichiarato
Ragione sociale	Toscana Diagnostica S.r.l.
Codice Fiscale / Partita IVA	07528130482
Sede legale	Viale Belfiore 55 — 50144 Firenze (FI)
PEC istituzionale	toscanadiagnostica@pec.it
Codice domanda di registrazione (DNISA)	DNISA00056699
Data di trasmissione registrazione	27 aprile 2026
Ruolo del dichiarante	Legale Rappresentante
Gruppo di imprese (CNT 2.1)	L'organizzazione non fa parte di un gruppo
Imprese collegate (CNT 3.1)	Nessuna ai sensi della Determinazione ACN 38565/2024

4.2 Caratterizzazione (CRT) e tipologia di soggetto (TDS)

I codici ATECO dichiarati in fase di registrazione sono: 70.20.09 (Consulenza imprenditoriale e altre attività di consulenza gestionale n.c.a.), 86.9 (Altre attività per la salute umana), 86.91.01 (Attività di diagnostica per immagini). La dimensione dichiarata corrisponde a un fatturato superiore a 2 milioni di euro e non superiore a 10 milioni, un bilancio compreso negli stessi limiti e un numero di effettivi tra 50 e 249 unità, calcolati ai sensi della Raccomandazione 2003/361/CE. Il settore di appartenenza è il settore Sanitario; la tipologia di soggetto dichiarata è "Prestatori di assistenza sanitaria" quali definiti all'art. 3 lett. g) della Direttiva 2011/24/UE.

4.3 Conferma valutazione preliminare di sistema (CVPS)

All'esito dell'autovalutazione condotta sulla base dei criteri di cui all'art. 6 del D.Lgs. 138/2024 e della tipologia di soggetto sopra indicata, Toscana Diagnostica si è autoclassificata come Soggetto Importante. Tale classificazione comporta l'adesione integrale alle MTOM previste dall'art. 24 del D.Lgs. 138/2024, gli obblighi di notifica degli incidenti significativi al CSIRT Italia ai sensi dell'art. 25, la designazione del Punto di Contatto ai sensi dell'art. 8, la sottoposizione ai poteri di vigilanza ex post di ACN ai sensi dell'art. 30, e l'esposizione a sanzioni amministrative pecuniarie fino a 7 milioni di euro o all'1,4% del fatturato annuo mondiale, a seconda del valore maggiore, ai sensi dell'art. 38.

4.4 Mantenimento e aggiornamento dei dati di registrazione

Il Punto di Contatto NIS, con il supporto del RSIG, garantisce l'aggiornamento periodico delle informazioni dichiarate sul Portale ACN. La finestra ordinaria di rinnovo annuale è compresa tra il 1° gennaio e il 28 febbraio di ciascun anno. Ogni variazione rilevante (cambio sede legale, modifica della classificazione, attivazione di nuove linee di servizio, variazioni dimensionali con superamento delle soglie 2003/361/CE, fusioni, scissioni, conferimenti, modifiche del Punto di Contatto) deve essere comunicata sul Portale entro 14 giorni lavorativi dall'evento. Ogni dichiarazione e ciascun codice DNISA assegnato dall'ACN sono archiviati nel fascicolo NIS dell'Area 08 del SIG come evidenza documentale per audit.

Toscana Diagnostica S.r.l.

Via di Pratignone, 13/4, 50019 Sesto Fiorentino (FI). Tel. e Fax: 055776511. Direttore Sanitario: prof. Gian Luigi Taddei.
P.IVA e C.F.: 07528130482, REA n. FI-709602 – Capitale Sociale: € 50.000,00 i.v.

5. Ruoli e responsabilità

La presente sezione individua i ruoli interni di Toscana Diagnostica coinvolti nell'attuazione della procedura NIS2 e ne sintetizza le responsabilità in una matrice RACI (R = Responsabile, A = Approvatore, C = Consultato, I = Informato).

5.1 Descrizione dei ruoli

L'Alta Direzione, in persona del Legale Rappresentante e Amministratore Delegato, approva la presente procedura e ogni sua revisione, garantisce l'allocazione delle risorse economiche e organizzative necessarie all'adeguamento NIS2, designa formalmente il Punto di Contatto NIS e il sostituto, riceve e valida il riesame periodico annuale di conformità, autorizza la trasmissione delle notifiche di incidente significativo nei casi che richiedano il suo intervento decisionale e vigila sull'adempimento degli obblighi di formazione obbligatoria previsti dall'art. 23 c. 4 del D.Lgs. 138/2024.

Il Responsabile del Sistema di Gestione Integrato (RSGI) presidia l'aggiornamento e il mantenimento della procedura, coordina le verifiche periodiche di conformità con il DPO, l'IT Manager e l'OdV, garantisce l'integrazione della procedura NIS2 con il Sistema di Gestione della Sicurezza delle Informazioni ISO/IEC 27001 e con il futuro Sistema di Gestione della Continuità Operativa ISO 22301, e presenta il dossier di Riesame annuale di conformità NIS2 alla Direzione.

Il Punto di Contatto NIS, designato dall'Alta Direzione e registrato sul Portale ACN, rappresenta Toscana Diagnostica verso ACN e CSIRT Italia per ogni adempimento, mantiene aggiornati sul Portale ACN i dati di registrazione, riceve le segnalazioni di possibili incidenti significativi dal personale e dai fornitori ICT critici, coordina la trasmissione della pre-allerta entro 24 ore, della notifica completa entro 72 ore e della relazione finale entro 30 giorni, assicura l'archiviazione documentata di ogni comunicazione con ACN/CSIRT Italia e dei relativi codici DNISA, e partecipa alle iniziative di information sharing previste dall'ACN.

L'IT Manager (responsabile dei sistemi informativi e della sicurezza ICT) implementa e manutiene le Misure Tecniche e Organizzative Minime di cui al §7, gestisce il monitoraggio continuo dell'infrastruttura, il triage degli alert SIEM/EDR e il rilevamento degli incidenti, produce la documentazione tecnica delle notifiche (timeline, IoC, vettori di attacco, sistemi compromessi, dati impattati), valida il livello di gravità degli incidenti secondo la tassonomia ACN, coordina la risposta tecnica e il ripristino in caso di incidente significativo, e tiene aggiornato l'inventario degli asset ICT e dei fornitori critici.

Il Data Protection Officer (DPO) valuta se l'incidente NIS2 costituisca anche un "data breach" ai sensi dell'art. 33 GDPR, attiva il flusso di notifica al Garante Privacy entro 72 ore e, se necessario, agli interessati ai sensi dell'art. 34 GDPR, garantisce la coerenza fra la notifica al CSIRT Italia e la notifica al Garante anche dal punto di vista contenutistico e cronologico, e presidia l'aggiornamento del Registro dei Data Breach (TD-SGI-REG007_00).

L'Organismo di Vigilanza ex D.Lgs. 231/2001 riceve i flussi informativi su qualsiasi incidente significativo che possa configurare un reato presupposto del decreto, in particolare in materia di reati informatici ex art. 24-bis e di reati introdotti dalla L. 90/2024, riceve gli esiti degli audit interni di conformità NIS2 e viene informato di eventuali sanzioni o procedimenti istruttori avviati dall'ACN.

Tutto il personale, inclusi i collaboratori esterni e i fornitori in servizio presso le sedi di Toscana Diagnostica, ha l'obbligo di segnalare tempestivamente al Punto di Contatto NIS o all'IT Manager qualunque evento sospetto, anomalia o incidente potenzialmente rilevante, di rispettare le politiche di sicurezza ICT e privacy in vigore e di partecipare ai programmi obbligatori di formazione NIS2 di cui al §9.

5.2 Matrice di responsabilità (RACI)

R = Responsabile, A = Approvatore, C = Consultato, I = Informato.

Attività	AD	RSIG	Punto Contatto NIS	IT Manager	DPO	OdV
Approvazione e revisione della procedura	A	R	C	C	C	I
Designazione del Punto di Contatto NIS	A/R	C	—	C	I	I
Mantenimento dei dati di registrazione su Portale ACN	I	C	R	C	I	I
Triage e classificazione di un incidente	I	C	R	R	C	I
Trasmissione pre-allerta (24h)	I	I	R	C	C	I
Trasmissione notifica completa (72h)	I	I	R	C	C	I
Trasmissione relazione finale (30gg)	I	C	R	C	C	I
Notifica GDPR al Garante (se data breach)	I	C	C	C	R	I
Implementazione MTOM	I	A	C	R	C	I
Due diligence e qualificazione fornitori ICT critici	A	C	C	R	C	I
Audit interno di conformità NIS2	I	R	C	C	C	I
Esercitazioni di simulazione (tabletop)	I	R	R	C	C	I
Formazione obbligatoria NIS2	A	R	C	C	C	I
Riesame annuale di conformità NIS2 alla Direzione	A	R	C	C	C	I
Comunicazione di crisi al pubblico (se richiesta)	A	C	R	C	C	I

6. Gestione degli incidenti significativi e notifica al CSIRT Italia

6.1 Definizione di incidente significativo

Ai sensi dell'art. 25 del D.Lgs. 138/2024 e del Regolamento di esecuzione (UE) 2024/2690, un incidente di sicurezza è qualificato come "significativo" — e quindi soggetto a obbligo di notifica al CSIRT Italia — se ha causato o è in grado di causare una grave perturbazione operativa dei servizi o una perdita finanziaria per il soggetto, oppure se ha avuto o è in grado di avere ripercussioni su altre persone fisiche o giuridiche, causando danni materiali o immateriali considerevoli, oppure se soddisfa le ulteriori soglie quantitative e qualitative settoriali definite dal Regolamento UE 2024/2690 e dalle Determinazioni ACN per il settore sanitario (a titolo esemplificativo: ore di indisponibilità di servizi clinici, numero di pazienti impattati, tipologia di dati clinici compromessi, attivazione di procedure di disaster recovery).

6.2 Catena di risposta e tempistiche

La catena di risposta è strutturata in cinque fasi consecutive con tempistiche stringenti, riepilogate nella tabella seguente. Il momento iniziale T0 corrisponde all'istante di conoscenza dell'evento da parte di un soggetto interno qualificato (operatore IT, Punto di Contatto NIS, fornitore critico).

Fase	Attività	Responsabile	Timing target
1. Rilevazione	Identificazione dell'evento (alert SIEM/EDR, segnalazione utente, notifica fornitore)	IT Manager	T0 = istante di conoscenza
2. Triage e	Valutazione preliminare di gravità, perimetro,	IT Manager + Punto	T0 + 4-8 ore

classificazione	dati impattati; verifica delle soglie NIS2 e GDPR	Contatto + DPO	
3. Pre-allerta	Trasmissione della pre-allerta al CSIRT Italia tramite Portale ACN, con prima descrizione e indicazione di eventuale natura dolosa o impatto transfrontaliero	Punto di Contatto NIS	Entro 24 ore da T0
4. Notifica completa	Trasmissione della notifica completa con valutazione iniziale, gravità, impatto, IoC noti, misure di mitigazione	Punto di Contatto NIS	Entro 72 ore da T0
5. Relazione finale	Trasmissione della relazione conclusiva con descrizione dettagliata, causa, gravità, impatto effettivo, misure adottate, lessons learned	Punto di Contatto NIS + IT Manager	Entro 1 mese dalla notifica completa
Eventuale 5-bis. Rapporto di stato	Se incidente non risolto a 30gg: trasmissione di un rapporto di avanzamento; relazione finale entro 30gg dal contenimento	Punto di Contatto NIS	Su richiesta CSIRT o se non chiuso

6.3 Coordinamento con la notifica GDPR

Quando l'incidente comporta la violazione di dati personali (in particolare dati relativi alla salute, ex art. 9 GDPR), si attiva in parallelo il flusso di notifica GDPR coordinato dal DPO secondo TD-SGI-PRO019_00 e TD-SGI-REG007_00. La notifica al Garante Privacy ai sensi dell'art. 33 GDPR deve avvenire entro 72 ore dalla conoscenza, con identica decorrenza rispetto alla notifica completa NIS2: i due flussi devono essere mantenuti coerenti su contenuti, gravità dichiarata, perimetro impattato e misure adottate. Il fascicolo dell'incidente, custodito dal RSGI, riporta entrambe le evidenze.

6.4 Comunicazione ai destinatari del servizio

Ai sensi dell'art. 25 c. 5 del D.Lgs. 138/2024, qualora il CSIRT Italia o l'ACN ritengano necessaria la comunicazione dell'incidente al pubblico o ai destinatari dei servizi, Toscana Diagnostica predispone — entro le tempistiche indicate dall'Autorità — comunicazioni coerenti con la procedura di Comunicazione di Crisi (TD-SGI-PRO054_00, allegato MOD179 "Checklist Comunicazione di Crisi"), curate dal Retail & Communications Manager con validazione del Punto di Contatto NIS e del DPO.

6.5 Registro degli incidenti significativi NIS2

Il Punto di Contatto NIS, con il supporto del RSGI, mantiene il "Registro degli Incidenti Significativi NIS2" (modulo TD-SGI-MOD181_00, in elaborazione), articolato sui seguenti campi: identificativo interno, data/ora di rilevazione (T0), descrizione sintetica, tipologia (riservatezza, integrità, disponibilità, autenticità), perimetro impattato, livello di gravità ACN, codici DNISA assegnati per pre-allerta, notifica completa e relazione finale, eventuale notifica GDPR (Garante), responsabile del fascicolo, stato (aperto, in lavorazione, chiuso), lessons learned, follow-up.

7. Misure tecniche e organizzative minime

7.1 Mappatura delle 10 aree MTOM ai controlli ISO/IEC 27001 e al SGI

Toscana Diagnostica adotta un approccio basato sulla gestione del rischio coerente con l'art. 24 del D.Lgs. 138/2024 e con i controlli ISO/IEC 27001:2022 Annex A. Le 10 macro-aree MTOM richieste dalla NIS2 sono mappate sul SGI come segue.

Area MTOM (art. 24)	Riferimento	ISO/IEC	Procedure / asset	SGI di Toscana
---------------------	-------------	---------	-------------------	----------------

Toscana Diagnostica S.r.l.

Via di Pratignone, 13/4, 50019 Sesto Fiorentino (FI). Tel. e Fax: 055776511. Direttore Sanitario: prof. Gian Luigi Taddei.
P.IVA e C.F.: 07528130482, REA n. FI-709602 – Capitale Sociale: € 50.000,00 i.v.

	27001 Annex A	Diagnostica
a) Politiche di analisi dei rischi e di sicurezza dei sistemi informativi	5.1, 5.36; clausole 6.1 e 8.2 (ISO 27005)	POL001 Politica integrata; Risk register SGSI; presente PRO070; PRO019 (incidenti ICT)
b) Gestione degli incidenti	5.24, 5.25, 5.26, 5.27, 5.28; clausola 10.1	PRO019 (incidenti ICT) integrata con il §6 della presente; MOD181 Registro Incidenti
c) Continuità operativa, backup, disaster recovery, gestione delle crisi	5.29, 5.30, 8.13, 8.14	Procedura BC futura ISO 22301; policy backup; MOD179 Checklist Comunicazione Crisi
d) Sicurezza della catena di approvvigionamento	5.19, 5.20, 5.21, 5.22, 5.23	PRO034 Qualificazione fornitori; PRO006 Due diligence partner; §8 della presente PRO070
e) Sicurezza in acquisizione, sviluppo e manutenzione dei sistemi; gestione delle vulnerabilità	8.25, 8.26, 8.27, 8.28, 8.29; 8.8 (vulnerability mgmt)	Policy SDLC; vulnerability assessment annuale; processo patch management
f) Politiche e procedure per la valutazione dell'efficacia delle misure	Clausole 9.1, 9.2, 9.3 (gestione SGSI)	PRO007 Audit interno; piano riesame della Direzione (Area 10); KPI cybersecurity §10
g) Pratiche di igiene informatica di base e formazione cybersecurity	5.4, 6.3, 8.7	Piano formazione §9 della presente; e-learning ricorrente; phishing simulation semestrale
h) Politiche e procedure relative all'uso della crittografia	8.24	Policy crittografica SGSI; cifratura at-rest e in-transit dei dati clinici; gestione chiavi
i) Sicurezza delle risorse umane, controllo accessi, gestione asset	6.1-6.6; 8.1-8.6; 5.9-5.13	Procedure HR onboarding/offboarding (Area 12); IAM aziendale; inventario asset (MOD014)
j) Autenticazione a più fattori e comunicazioni vocali, video e testuali protette	8.5; 8.20-8.23	MFA obbligatoria per LIS, RIS, VPN e accessi amministrativi; canali video/testo conformi GDPR e ISO 27001

7.2 Piano di adeguamento MTOM

L'IT Manager, con la supervisione del RSGI, redige e mantiene il "Piano di Adeguamento MTOM" — documento di lavoro interno articolato per ciascuna delle 10 aree, contenente la misura attuale (as-is), il gap rispetto alle Determinazioni ACN, l'azione correttiva, l'owner, la milestone e l'evidenza di chiusura. Il piano è oggetto di Riesame della Direzione almeno annuale; l'aggiornamento operativo è trimestrale.

7.3 Tempistica di adeguamento

Coerentemente con le scadenze del Decreto NIS e delle Determinazioni ACN attuative, l'attuazione integrale delle MTOM è programmata entro il 1° ottobre 2026. La verifica documentale di completamento è condotta dal RSGI con audit ad hoc nelle settimane antecedenti la scadenza. Le evidenze di completamento sono trasmesse all'OdV.

8. Gestione dei fornitori ICT critici

8.1 Inventario e classificazione

L'IT Manager mantiene l'inventario dei fornitori ICT (modulo TD-SGI-MOD182_00, in elaborazione) articolato per ciascun fornitore sui campi: ragione sociale, P.IVA, servizio erogato, tipologia (SaaS, IaaS, PaaS, on-premise, software house, MSP, supporto tecnico, servizi gestiti), criticità (Alta, Media, Bassa secondo la metodologia §8.2), stato delle certificazioni (ISO/IEC 27001, ISO/IEC 27017, ISO/IEC 27018, SOC 2), data ultima due diligence, esito audit fornitore, contratti applicabili.

8.2 Metodologia di classificazione della criticità

La criticità di un fornitore è valutata sulla base di tre criteri: (i) impatto sui processi clinici/operativi, considerando la natura del servizio erogato (servizio core di erogazione clinica vs. servizio di supporto vs. servizio accessorio); (ii) tipologia e volume dei dati trattati, considerando le categorie di dati personali e clinici trattati dal fornitore (categorie particolari ex art. 9 GDPR vs. dati comuni); (iii) sostituibilità e tempi di disaster recovery, considerando il tempo massimo tollerabile di indisponibilità del fornitore prima che si determini un impatto significativo (RTO). Combinando i tre criteri, ciascun fornitore è classificato come "Critico (Alta)", "Rilevante (Media)" o "Standard (Bassa)". I fornitori "Critici" sono soggetti agli obblighi rafforzati dei §§ 8.3-8.6.

8.3 Due diligence iniziale e qualificazione

Per ciascun fornitore ICT classificato "Critico", prima della stipula del contratto, è obbligatoria una due diligence di sicurezza che include la verifica delle certificazioni di sicurezza con priorità all'ISO/IEC 27001, la richiesta del SOA (Statement of Applicability) e del rapporto di audit più recente, la verifica della giurisdizione di trattamento dei dati e delle clausole di trasferimento extra-UE (SCCs ex art. 46 GDPR), la verifica della disponibilità di un piano di Business Continuity testato e di un SLA con penali esplicite, la verifica della catena di subfornitura e dell'applicabilità delle clausole NIS2/GDPR a cascata. L'esito è formalizzato con il modulo TD-SGI-MOD041_00 "Classificazione del Fornitore" e archiviato a cura del Procurement con copia per IT Manager e RSGI.

8.4 Clausole contrattuali NIS2

I contratti con i fornitori ICT "Critici" devono includere — direttamente o tramite addendum — almeno otto clausole minime, come riepilogato nella tabella seguente.

#	Clausola contrattuale minima
1	Obbligo di rispetto delle MTOM equivalenti a quelle imposte a Toscana Diagnostica
2	Notifica al Punto di Contatto NIS di Toscana Diagnostica entro 12 ore dalla conoscenza di un incidente impattante, in modo da consentire il rispetto della scadenza di 24 ore al CSIRT Italia
3	Collaborazione attiva nella fase istruttoria di ACN/CSIRT Italia, inclusa la fornitura tempestiva di evidenze tecniche
4	Diritto di audit annuale (in proprio o tramite terzo indipendente)
5	Limitazioni puntuali al subaffidamento e divieto di trasferimento dei dati al di fuori delle giurisdizioni autorizzate
6	Clausole di reversibilità e exit con tempistiche, formati e modalità di restituzione/cancellazione dei dati
7	Clausole di responsabilità solidale per i danni derivanti da inadempienze NIS2/GDPR del fornitore
8	Obbligo di formazione del personale del fornitore in materia di cybersicurezza

8.5 Monitoraggio periodico e audit

Per i fornitori "Critici" è previsto un riesame annuale per la verifica della validità delle certificazioni (in particolare ISO/IEC 27001) e la revisione del SOA, un audit periodico in proprio o di terza parte secondo PRO007 almeno una volta nel triennio per ciascun fornitore Critico, un monitoraggio operativo dei KPI contrattuali (uptime, MTTR, n. incidenti) e dei flussi di security advisories ricevuti, e l'attivazione del meccanismo di incident sharing per cui qualunque incidente dichiarato dal fornitore è registrato sul Registro Incidenti NIS2 (MOD181) anche quando non costituisca incidente significativo per Toscana Diagnostica.

8.6 Disimpegno dei fornitori non conformi

In caso di mancato rispetto reiterato delle clausole NIS2 o di mancato adeguamento entro il termine fissato in fase di audit, Toscana Diagnostica avvia il procedimento di disimpegno coordinato dal Procurement, dal RSGI e dal Legal Counsel, con piano di transizione a fornitore alternativo conforme. Il procedimento è documentato e portato a conoscenza dell'OdV.

9. Formazione, audit e miglioramento continuo

9.1 Piano di formazione obbligatoria

Coerentemente con l'art. 23 c. 4 del D.Lgs. 138/2024, l'Alta Direzione e il personale rilevante devono frequentare con cadenza periodica un percorso formativo specifico in materia di cybersicurezza. Il piano formativo NIS2 è articolato come riportato di seguito.

Destinatari	Contenuto	Modalità	Frequenza	Evidenza
Alta Direzione + Comitato Guida SGI	Obblighi NIS2, responsabilità apicali, governance del rischio cyber, sanzioni	Sessione frontale + e-learning	Annuale	Attestato + verbale
Punto di Contatto NIS + sostituto	Procedure di registrazione, notifica incidenti, dialogo ACN, esercitazioni	Corso esterno specialistico + simulazioni	Annuale + on-event	Attestato di superamento
IT Manager + Team IT	MTOM, secure SDLC, incident response, threat intelligence	Corso esterno + workshop interno	Annuale	Attestato + log laboratorio
Personale clinico e amministrativo	Igiene cyber di base, riconoscimento phishing, gestione password, segnalazione eventi	E-learning + phishing simulation	Annuale + simulazioni semestrali	Completamento e-learning + report simulazioni
Fornitori ICT critici	Estensione delle policy aziendali ai fornitori, allineamento sui flussi di notifica	Briefing in occasione del riesame contrattuale	Annuale	Verbale di briefing

9.2 Audit interno NIS2

L'audit interno NIS2 è condotto dal RSGI con cadenza annuale, secondo il programma di audit dell'Area 10 e in coerenza con TD-SGI-PRO007_00. L'audit verifica la completezza e la tempestività dei dati di registrazione ACN, la tracciabilità dei codici DNISA per tutte le pratiche aperte e chiuse nell'esercizio, la completezza del Registro Incidenti NIS2 e le tempistiche effettive di notifica, lo stato

delle MTOM (percentuale di completamento, gap aperti, azioni correttive in corso), lo stato della classificazione fornitori ICT e la conformità delle clausole contrattuali, il completamento dei piani formativi obbligatori da parte di tutto il personale rilevante, gli esiti delle phishing simulation e dei tabletop exercise di incident response.

9.3 Esercitazioni di simulazione

È programmata almeno una esercitazione di simulazione di incidente significativo (tabletop exercise) all'anno, con il coinvolgimento dell'Alta Direzione, del Punto di Contatto NIS, dell'IT Manager, del DPO e del Retail & Communications Manager. Lo scenario di simulazione include la decisione di pre-allerta, la gestione delle 72 ore, la coerenza con la notifica GDPR, la comunicazione interna e ai pazienti. Il rapporto di esercitazione è archiviato nel fascicolo NIS dell'Area 08.

9.4 Riesame della Direzione

Lo stato di conformità NIS2 — sintetizzato in un dossier dedicato dal RSGI — è oggetto di trattazione in sede di Riesame della Direzione del SGI almeno con cadenza annuale. Il dossier include la registrazione e gli aggiornamenti ACN, le statistiche degli incidenti dell'anno, gravità, tempistiche di notifica, esiti audit, esiti formazione, KPI, gap aperti, piano d'azione 12 mesi.

10. Indicatori di processo

Il presidio della conformità NIS2 è governato da un set di indicatori chiave (KPI) che alimentano il cruscotto direzionale del SGI.

KPI	Definizione	Target	Frequenza
Tempestività pre-allerta	N. pre-allerte trasmesse a CSIRT Italia entro 24h / totale incidenti significativi	100%	Trimestrale
Tempestività notifica completa	N. notifiche complete entro 72h / totale incidenti significativi	100%	Trimestrale
Tempestività relazione finale	N. relazioni finali entro 30gg dalla notifica completa / totale	100%	Trimestrale
Aggiornamento dati ACN	Aggiornamenti annuali entro 28 febbraio + aggiornamenti straordinari entro 14gg	100%	Annuale + on-event
Stato MTOM	Percentuale di MTOM in stato "completo" sulle 10 aree	≥ 100% al 1/10/2026	Trimestrale
Copertura formazione obbligatoria	Personale rilevante con formazione completata / totale	≥ 95%	Semestrale
Phishing failure rate	Click rate medio alle simulazioni di phishing	≤ 5%	Semestrale
Vulnerabilità critiche aperte > 30gg	N. CVE critiche non patchate da oltre 30 giorni	0	Mensile
Audit fornitori critici	Fornitori critici con audit nel triennio / totale	100% nel triennio rolling	Annuale
Esercitazioni di simulazione	Tabletop exercises completati / programmati	≥ 1/anno	Annuale

11. Archiviazione, riservatezza e tracciabilità

Tutta la documentazione NIS2 — dichiarazioni ACN, codici DNISA, registri, fascicoli incidenti, audit, evidenze MTOM, piani formativi, dossier di Riesame — è archiviata digitalmente nella cartella

protetta dell'Area 08 con accesso ristretto ai soggetti elencati al §5. La conservazione minima è di 10 anni, in coerenza con i termini prescrizionali delle sanzioni amministrative ACN. I documenti NIS2 sono classificati "Riservato" ai sensi della classificazione interna del SGI; la loro divulgazione esterna richiede autorizzazione esplicita dell'Amministratore Delegato o del Punto di Contatto NIS, fatte salve le comunicazioni dovute per legge ad ACN, CSIRT Italia, Garante Privacy, Autorità Giudiziaria.

12. Allegati, moduli e registri collegati

Sono allegati alla presente procedura — o connessi alla stessa per finalità operativa — i seguenti moduli e registri.

Codice	Tipo	Titolo	Stato
TD-SGI-MOD181_00	Modulo	Registro degli Incidenti Significativi NIS2	In elaborazione (emissione entro maggio 2026)
TD-SGI-MOD182_00	Modulo	Inventario e classificazione dei Fornitori ICT critici	In elaborazione (emissione entro maggio 2026)
TD-SGI-MOD183_00	Modulo	Verbale di tabletop exercise NIS2	In elaborazione
TD-SGI-MOD184_00	Modulo	Checklist Pre-allerta / Notifica completa / Relazione finale	In elaborazione
TD-SGI-IDL026_00	Istruzione di lavoro	Trasmissione delle notifiche al Portale ACN	In elaborazione
TD-SGI-PRO019_00	Procedura	Gestione incidenti ICT e data breach (Area 08)	In vigore
TD-SGI-REG007_00	Registro	Registro dei Data Breach (Area 09)	In vigore
TD-SGI-PRO034_00	Procedura	Qualificazione e valutazione fornitori (Area 14)	In vigore
TD-SGI-PRO054_00	Procedura	Comunicazione interna ed esterna (Area 01) — per crisi	In vigore
DNISA00056699	Dichiarazione	Conferma di registrazione ACN del 27/04/2026	Allegato esterno

13. Storico delle revisioni

Rev.	Data	Descrizione	Autore
00	28/04/2026	Prima emissione. Recepisce la registrazione ACN DNISA00056699 del 27/04/2026 e si allinea alle scadenze NIS2 vincolanti del 1° ottobre 2026. Copre registrazione ACN, gestione e notifica incidenti significativi (24h/72h/30gg), 10 aree MTOM ex art. 24 D.Lgs. 138/2024, gestione fornitori ICT critici, formazione obbligatoria art. 23 c. 4, KPI di monitoraggio. Sarà oggetto di revisione successiva all'emissione delle Determinazioni ACN attuative finali e dei moduli MOD181-184 e IDL026 collegati.	RSGI